PRO2

Investigación comparativa de plataformas de simulación de phishing

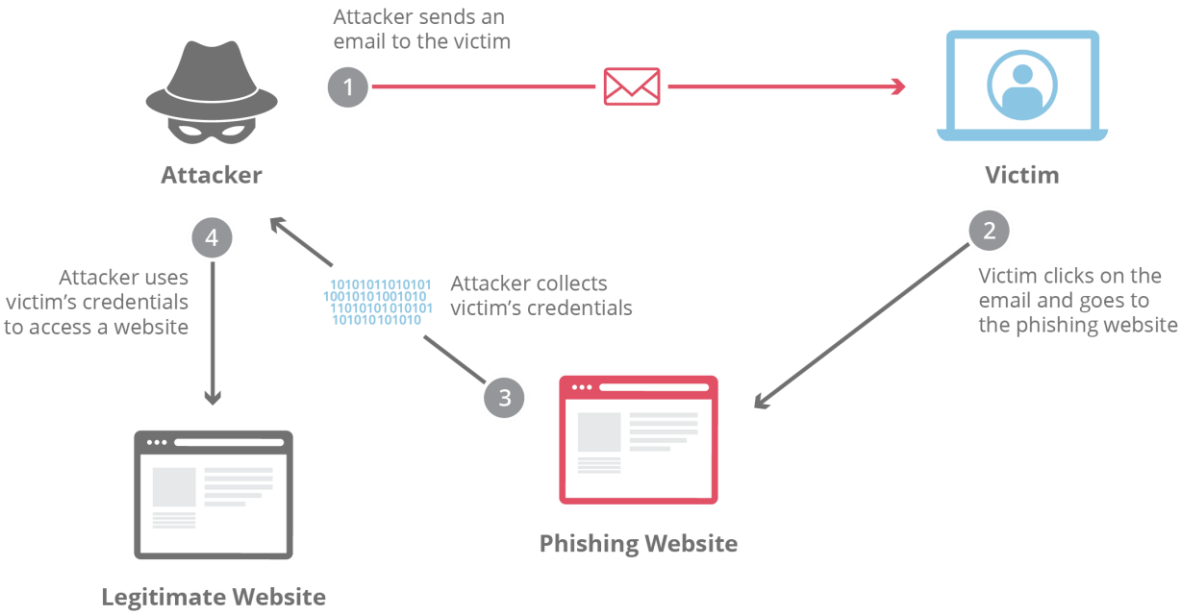
EDAURDO GABRIEL MORQUECHO MEDINA
175805
UNIVERSIDAD POLITECNICA DE SAN LUIS POTOSI

Contenido

Introducción 2
Marco teórico 3
Plataformas de simulación de phishing 4
Hoxhunt 4
Proofpoint 5
KnowBe4 6
Cofense 6
Phished 7
NINJIO 8
Mimecast 9
Infosec IQ 9
Tabla comparativa técnica 0
Análisis crítico 0
Conclusión 0
REFERENCIAS 0

Introducción

El phishing se refiere a un intento de robar información confidencial, generalmente nombres de usuario, contraseñas, números de tarjetas de crédito, información bancaria u otros datos importantes, para utilizarla o venderla. Al hacerse pasar por una fuente confiable con una solicitud atractiva, un atacante atrae a la víctima para engañarla, de forma similar a como un pescador usa cebo para pescar.



El phishing es una de las principales amenazas de seguridad informática, responsable de más del 90 % de los ataques exitosos en muchas organizaciones. La mayoría de estos incidentes explotan el factor humano, lo que ha impulsado el desarrollo de plataformas especializadas en simulación de phishing y entrenamiento de concienciación en seguridad.

Estas plataformas buscan reducir el riesgo humano mediante tres componentes clave:

1. Simulación de ataques realistas
2. Entrenamiento continuo del usuario
3. Análisis de comportamiento y métricas de riesgo

Entre las soluciones líderes del mercado se encuentran:

- Hoxhunt
- Proofpoint
- KnowBe4
- Cofense
- Phished
- NINJIO

- Mimecast
- Infosec IQ

Estas herramientas permiten evaluar el comportamiento de los usuarios frente a ataques simulados y medir su evolución mediante indicadores cuantitativos como:

Métricas principales utilizadas

1. Click Rate (Phish-prone rate)
Porcentaje de usuarios que hacen clic en enlaces o interactúan con correos simulados.

2. Reporting Rate
Porcentaje de usuarios que detectan y reportan correctamente un phishing.

3. Risk Score (Human Risk Score)
Índice calculado a partir del comportamiento del usuario frente a ataques simulados y reales.

4. Time-to-report

Tiempo que tarda el usuario en reportar un correo sospechoso.

En programas maduros de entrenamiento, las plataformas priorizan reporting rate y tiempo de reporte sobre click rate, ya que reflejan cambios positivos de comportamiento y cultura de seguridad.

Marco teórico

El phishing es una de las formas más comunes de ingeniería social. Consiste en el envío de correos electrónicos o mensajes fraudulentos que imitan comunicaciones legítimas con el objetivo de engañar al usuario para que realice una acción peligrosa, como hacer clic en un enlace malicioso o descargar un archivo infectado. Las plataformas de simulación de phishing tienen como objetivo entrenar a los usuarios para reconocer estas amenazas. Estas soluciones funcionan mediante campañas simuladas que permiten medir la respuesta de los empleados ante ataques controlados. Existen tres pilares fundamentales en el diseño de estas plataformas:

1. Entrenamiento continuo mediante micro aprendizaje.

2. Simulación realista basada en amenazas reales.

3. Métricas de comportamiento que permitan medir el riesgo humano dentro de la organización.

Plataformas de simulación de phishing

Hoxhunt

Hoxhunt es una plataforma de gestión del riesgo humano que utiliza inteligencia artificial para generar simulaciones personalizadas de phishing. La herramienta analiza el comportamiento del usuario, su rol dentro de la organización y su historial de interacción con campañas anteriores para adaptar la dificultad de los ataques simulados. Su enfoque principal consiste en convertir a los empleados en participantes activos del sistema de seguridad. Para lograrlo, la plataforma incorpora mecanismos de gamificación que recompensan a los usuarios que reportan correos sospechosos.

Tipo: Plataforma adaptativa de entrenamiento y simulación de phishing basada en comportamiento.

Características técnicas

- Simulaciones automáticas adaptadas al nivel del usuario.
- Integración directa con clientes de correo (Outlook, Gmail).
- Gamificación del aprendizaje.
- Análisis de comportamiento basado en IA.

Métricas principales

- Reporting rate
- Failure rate
- Time-to-report
- Real threat detection rate

El enfoque de Hoxhunt prioriza medir comportamientos positivos (reportar ataques) en lugar de castigar errores.

Enfoque de entrenamiento

- Micro-learning
- Feedback inmediato
- Gamificación

Análisis crítico

Ventajas:

- Alto nivel de personalización.

- Enfoque moderno centrado en comportamiento.

Limitaciones:

- Menor biblioteca de contenido comparado con plataformas tradicionales.

Proofpoint

Proofpoint es una empresa reconocida en el ámbito de la seguridad del correo electrónico. Su plataforma de concientización se integra directamente con su sistema de protección de correo, permitiendo utilizar datos de ataques reales para generar simulaciones de phishing. Uno de sus conceptos más importantes es el modelo VAP (Very Attacked People), el cual identifica a los usuarios que reciben más ataques dentro de la organización y les asigna entrenamiento especializado.

Tipo: Plataforma integrada de concienciación y análisis de riesgo humano.

Características técnicas

- Simulaciones de phishing realistas basadas en inteligencia de amenazas.
- Integración con sistemas de seguridad de correo.
- Automatización de entrenamiento según riesgo del usuario.

Métricas principales

- Susceptibility score
- User risk score
- Reporting rate
- Phish-prone percentage

Enfoque de entrenamiento

- Microlearning
- Campañas adaptativas
- Simulación multicanal (email, SMS, USB)

Análisis crítico

Ventajas:

- Integración con ecosistema de seguridad empresarial.
- Analítica avanzada basada en inteligencia de amenazas.

Limitaciones:

- Implementación más compleja que otras soluciones.

KnowBe4

KnowBe4 es una de las plataformas de entrenamiento en ciberseguridad más populares del mercado. Su enfoque combina simulaciones de phishing con una extensa biblioteca de contenido educativo que incluye videos, juegos y módulos interactivos. La plataforma utiliza métricas como el PhishProne Percentage para medir el porcentaje de usuarios que son vulnerables a ataques de phishing dentro de una organización.

Tipo: Plataforma líder de simulación de phishing y entrenamiento de seguridad.

Características técnicas

- Más de 1000 plantillas de phishing.
- Simulación de ataques avanzados.
- Risk scoring basado en machine learning.

Métricas principales

- Phish-prone percentage
- Risk score
- Completion rate
- Reporting rate

Enfoque de entrenamiento

- Biblioteca extensa de cursos
- Videos y simulaciones
- Campañas automatizadas

Análisis crítico

Ventajas:

- Biblioteca de contenido más grande del mercado.
- Amplio ecosistema de integraciones.

Limitaciones:

- Enfoque más orientado a compliance que a cambio conductual.

Cofense

Cofense se centra en el concepto de resiliencia organizacional. Su filosofía consiste en convertir a los empleados en sensores de seguridad capaces de detectar amenazas que logran evadir los sistemas

automáticos. La herramienta incluye funciones para reportar correos sospechosos y permitir a los equipos de seguridad analizar y neutralizar amenazas rápidamente.

Tipo: Plataforma centrada en respuesta a phishing y concienciación.

Características técnicas

- Simulación avanzada de phishing.
- Integración con SOC.
- Análisis de correos reportados.

Métricas principales

- Reported phishing rate
- User risk score
- Incident response metrics

Enfoque de entrenamiento

- Aprendizaje basado en incidentes reales
- Feedback contextual

Análisis crítico

Ventajas:

- Integración fuerte con equipos de respuesta a incidentes.

Limitaciones:

- Menor enfoque en gamificación o engagement.

Phished

Phished es una plataforma basada en inteligencia artificial que automatiza completamente las campañas de simulación de phishing. El sistema analiza el comportamiento de los usuarios y lanza simulaciones de forma automática sin necesidad de intervención manual por parte de los administradores.

Tipo: Plataforma europea basada en inteligencia artificial.

Características técnicas

- Simulaciones generadas por IA.
- Evaluación continua del riesgo humano.
- Aprendizaje adaptativo.

Métricas principales

- Human risk score
- Susceptibility score
- Reporting rate

Enfoque de entrenamiento

- Micro-learning automatizado
- Simulaciones adaptativas

Análisis crítico

Ventajas:

- IA para personalización avanzada.

Limitaciones:

- Menor adopción global.

NINJIO

NINJIO utiliza un enfoque educativo basado en storytelling. La plataforma entrega episodios animados cortos que explican incidentes reales de ciberseguridad, lo que facilita la retención del conocimiento por parte de los empleados.

Tipo: Plataforma de entrenamiento de seguridad con enfoque narrativo.

Características técnicas

- Videos estilo serie animada.
- Simulación de phishing.
- Evaluaciones posteriores.

Métricas principales

- Completion rate
- Click rate
- Quiz score

Enfoque de entrenamiento

- Storytelling
- Aprendizaje basado en entretenimiento

Análisis crítico

Ventajas:

- Alto nivel de engagement.

Limitaciones:

- Menor profundidad analítica.

Mimecast

Mimecast combina entrenamiento de seguridad con protección de correo electrónico. Gracias a su posición como proveedor de seguridad de correo, puede utilizar datos de amenazas reales para generar campañas de simulación más realistas.

Tipo: Plataforma integrada con seguridad de correo Mimecast.

Características técnicas

- Simulación de phishing.
- Integración con gateway de correo.
- Análisis de comportamiento.

Métricas principales

- Risk score
- Phish-prone rate
- Reporting rate

Enfoque de entrenamiento

- Simulaciones basadas en amenazas reales.

Análisis crítico

Ventajas:

- Integración fuerte con email security.

Limitaciones:

- Funcionalidad limitada fuera del ecosistema Mimecast.

Infosec IQ

Infosec IQ está orientada principalmente a organizaciones que necesitan cumplir con regulaciones de seguridad. La plataforma permite mapear los programas de capacitación con estándares como NIST e ISO 27001.

Tipo: Plataforma de entrenamiento de seguridad y simulación de phishing.

Características técnicas

- Biblioteca extensa de cursos.
- Simulación automatizada de phishing.
- Evaluaciones de cumplimiento.

Métricas principales

- Click rate
- Completion rate
- Risk score

Enfoque de entrenamiento

- Cursos estructurados
- Programas de compliance

Análisis crítico

Ventajas:

- Gran variedad de contenido educativo.

Limitaciones:

- Menor personalización conductual.

Tabla comparativa técnica

Plataforma	Tipo de entrenamiento	Diferenciador	Métricas principales	Métrica principal	Analítica avanzada	Integraciones	Enfoque	Enfoque ético	Limitaciones
Hoxhunt	Adaptativo gamificado	IA adaptativa	Reporting rate, failure rate, time-to-report	Tasa de reporte	Alta	Email clients, SIEM	Microaprendizaje	Enfoque positivo, no punitivo	Menos contenido
Proofpoint	Risk-based training	Amenazas reales	Risk score, reporting rate	Attack Index	Muy alta	Ecosistema Proofpoint	Entrenamiento dirigido	Análisis del riesgo humano	Implementación compleja
KnowBe4	Entrenamiento masivo	Gran biblioteca	Phish-prone rate, risk score	PPP	Alta	+100 integraciones	Gamificación	Enfoque compliance	Menos adaptativo
Cofense	Incident-driven	Reporte colaborativo	Reporting rate, incident metrics	Resiliency Ratio	Alta	SOC tools	Respuesta rápida	Basado en incidentes reales	Menos contenido
Phished	IA adaptativa	Automatización IA	Human risk score	Risk Score	Media-alta	API integrations	Entrenamiento adaptativo	Personalización IA	Menor adopción
NINJIO	Storytelling	Storytelling	Completion rate	Engagement	Media	LMS	Contenido audiovisual	Aprendizaje entretenido	Menos analítica
Mimecast	Integrado email security	Integración correo	Risk score	SAFE Score	Media	Mimecast ecosystem	Entrenamiento continuo	Basado en amenazas reales	Dependencia de plataforma
Infosec IQ	Compliance training	Cumplimiento normativo	Click rate, completion	Learner grade	Media	LMS	Entrenamiento por roles	Formación estructurada	Menos personalización

Análisis crítico

El análisis de las plataformas demuestra que cada solución tiene fortalezas particulares. Algunas plataformas se destacan por su integración con sistemas de seguridad existentes, mientras que otras priorizan el aprendizaje automatizado mediante inteligencia artificial. Por ejemplo, Proofpoint y Mimecast tienen ventajas en entornos donde ya se utilizan sus soluciones de seguridad de correo. Por otro lado, Hoxhunt y Phished destacan por su alto nivel de automatización. KnowBe4 ofrece la biblioteca educativa más amplia, mientras que Infosec IQ resulta especialmente útil para organizaciones que requieren cumplir con regulaciones estrictas.

Conclusión

El phishing sigue siendo una de las amenazas más comunes dentro de la ciberseguridad actual. Debido a esto, la capacitación de los usuarios se ha vuelto un elemento clave para reducir el riesgo de incidentes dentro de las organizaciones. Las plataformas de simulación de phishing ayudan a entrenar a los empleados mediante situaciones que imitan ataques reales, lo que les permite desarrollar la capacidad de identificar correos o mensajes maliciosos. Sin embargo, el uso de estas herramientas por sí solo no garantiza la seguridad. Su efectividad depende en gran parte de cómo se implementen dentro de la organización y de que exista una cultura de seguridad donde los usuarios participen activamente en la detección y reporte de amenazas.

REFERENCIAS

Cloudflare. (s.f.). *What is a phishing attack?* https://www.cloudflare.com/learning/access-management/phishing-attack/

Cofense. (s.f.). *Phishing defense solutions*. https://cofense.com

Hoxhunt. (s.f.). *Human risk management platform*. https://hoxhunt.com

KnowBe4. (s.f.). *Security awareness training platform*. https://www.knowbe4.com

Mimecast. (s.f.). *Security awareness training*. https://www.mimecast.com

NINJIO. (s.f.). *Cybersecurity awareness training*. https://ninjio.com

Phished. (s.f.). *AI-driven security awareness platform*. https://phished.io

Proofpoint. (s.f.). *Security awareness training*. https://www.proofpoint.com

Infosec Institute. (s.f.). *Infosec IQ platform*. https://www.infosecinstitute.com